

Etica, Società e Privacy

Risposte alle Domande d'Esame Più Frequenti

Università di Torino – Magistrale Informatica – A.A. 2024/2025

Indice

Introduzione

Questo documento risponde alle 22 domande d'esame più frequentemente poste nel corso di Etica, Società e Privacy (modulo Privacy) presso l'Università di Torino, integrate con 11 domande aggiuntive: 8 su argomenti trattati nel corso ma non coperti dalle prime 22 (AI Act, DSA, Data Act/Digital Omnibus, δ -presence, auditing, tipi di privacy e Big Data, classificazione/ciclo ML, interventi di fairness) e 3 emerse da un transcript di domande d'esame orale realmente poste (algoritmi SDC per macrodata/microdata, perché il nome "differential" privacy, domande di ragionamento aperto).

1 Differential Privacy

Domanda 1: Differential Privacy

Cos'è la Differential Privacy? Spiegare la definizione formale, la motivazione e come funziona.

La **Differential Privacy (DP)**, introdotta da Cynthia Dwork nel 2006 ("Calibrating Noise to Sensitivity in Private Data Analysis"), è un framework matematico rigoroso per rilasciare informazioni statistiche proteggendo contemporaneamente la privacy degli individui nel dataset.

Motivazione: vogliamo poter rispondere a query su un dataset senza rivelare informazioni sugli individui specifici. La DP garantisce che la presenza o l'assenza di un singolo individuo nel dataset abbia un impatto trascurabile sull'output della query.

Definizione formale: Due dataset D e D' si dicono *adiacenti* ($D \sim D'$) se differiscono per esattamente un record. Un meccanismo randomizzato $\mathcal{M} : \Omega \times Q \rightarrow \mathcal{R}$ preserva la ε -differential privacy se per qualsiasi query q , per ogni coppia di dataset adiacenti D, D' e per ogni possibile risposta $r \in \mathcal{R}$:

$$e^{-\varepsilon} \leq \frac{\mathbb{P}(\mathcal{M}(q, D) = r)}{\mathbb{P}(\mathcal{M}(q, D') = r)} \leq e^{\varepsilon}$$

Privacy budget ε : più piccolo è ε , maggiore è la garanzia di privacy; per $\varepsilon \rightarrow 0$ le due distribuzioni sono indistinguibili (massima privacy, minima utilità). Valori tipici: $\varepsilon \in [0.1, 5]$.

Meccanismo di Laplace: il principale meccanismo per query numeriche. Aggiunge rumore Laplaciano calibrato alla sensibilità della query:

$$\mathcal{M}_{Lap}(D, q) = q(D) + Lap\left(0, \frac{GS_1(q)}{\varepsilon}\right)$$

dove $GS_1(q) = \max_{D \sim D'} |q(D) - q(D')|$ è la *sensibilità globale* (il massimo cambiamento possibile dell'output togliendo/aggiungendo un record).

Teoremi fondamentali:

- **Post-processing:** qualunque elaborazione dell'output di un meccanismo DP non riduce la privacy.
- **Composizione:** due meccanismi ε_1 -DP e ε_2 -DP composti danno $(\varepsilon_1 + \varepsilon_2)$ -DP.
- **Composizione parallela:** applicare lo stesso meccanismo ε -DP su partizioni disgiunte del dataset mantiene ε -DP.

La DP offre una **garanzia matematicamente dimostrabile** contro qualsiasi forma di disclosure, indipendentemente dalla conoscenza pregressa dell'avversario.

Come lo spiegherei a voce

Il punto centrale da portare a voce è che la DP non protegge un dataset specifico, ma definisce una proprietà del *meccanismo* che lo elabora: se aggiungo o toglio una persona dal dataset, l'output che il meccanismo restituisce deve cambiare pochissimo (al massimo di un fattore e^ε). Questo significa che un osservatore che guarda solo la risposta non riesce a dire con certezza se quella persona era nel dataset o no. Il bello è che questa garanzia non dipende da cosa l'attaccante sa già, né dalla query specifica: vale sempre, per definizione, qualunque sia la query e qualunque sia il dataset.

2 Local e Global Differential Privacy

Domanda 2 & 9: Local e Global Differential Privacy

Qual è la differenza tra Local e Global Differential Privacy?

Global Differential Privacy (GDP) / Standard DP:

- Esiste un **curatore fidato** (trusted curator) che raccoglie i dati grezzi di tutti gli individui.
- La randomizzazione avviene *sul database aggregato* prima di rispondere alle query.
- L'indistinguibilità riguarda **dataset adiacenti** (differiscono per un solo record).
- Richiede meno rumore $\Rightarrow$ maggiore utilità.
- Esempio: il curatore raccoglie tutti i dati medici e risponde alle query aggiungendo rumore.

Local Differential Privacy (LDP):

- **Non c'è un curatore fidato.** Ogni individuo randomizza i propri dati *prima* di inviarli al raccogliitore.
- L'indistinguibilità riguarda **qualsiasi coppia di record** $x, x' \in U$ (non solo dataset adiacenti):

$$\mathbb{P}(\mathcal{M}(q, x) = r) \leq e^\epsilon \cdot \mathbb{P}(\mathcal{M}(q, x') = r) + \delta$$

- Richiede **molto più rumore** $\Rightarrow$ minore utilità.
- Esempio: Randomized Response, Apple (iOS), Google (Chrome Rappor).

Aspetto	GDP	LDP
Fiducia nel curatore	Sì	No
Dove si randomizza	Sul database	Sui singoli record
Indistinguibilità	Dataset adiacenti	Qualsiasi coppia di record
Quantità di rumore	Minore	Maggiore
Utilità	Maggiore	Minore

Randomized Response (LDP, Warner 1965): tecnica classica per sondaggi sensibili.

1. Lancia una moneta.
2. Testa: rispondi veridicamente.
3. Croce: lancia di nuovo e rispondi Sì/No in modo casuale.

$P(\text{Sì}|\text{vero}=\text{Sì}) = 3/4$, $P(\text{Sì}|\text{vero}=\text{No}) = 1/4$. Rapporto massimo: $\frac{3/4}{1/4} = 3 = e^{\log 3} \Rightarrow$ preserva $\log(3)$ -LDP.

Randomized Response Generalizzato per k categorie: $P(\mathcal{M}(x) = v) = \frac{e^\epsilon}{e^\epsilon + k - 1}$ se $v = q(x)$, altrimenti $\frac{1}{e^\epsilon + k - 1}$.

Come lo spiegherei a voce

La differenza si riduce a una domanda: di chi mi fido? Nel modello globale mi fido di chi raccoglie i dati (il curatore), quindi gli mando i miei dati veri e lui aggiunge il rumore prima di rispondere alle query – questo richiede poco rumore perché la randomizzazione si applica una sola volta, sull'intero database aggregato. Nel modello locale non mi fido di nessuno, quindi sono io stesso ad aggiungere rumore ai miei dati prima di spedirli, e qui il rumore deve essere molto più alto perché ogni singolo record, preso isolatamente, deve già essere indistinguibile da un altro – non c'è un aggregatore fidato che fa la randomizzazione “in un colpo solo”. Il Randomized Response è l'esempio più semplice di LDP: rispondo il vero con una certa probabilità e a caso con l'altra, e chi raccoglie i dati può ancora stimare le statistiche aggregate correggendo matematicamente per questo rumore, ma non può mai sapere con certezza la mia risposta vera.

3 Privacy e Security

Domanda 3: Privacy e Security

Qual è la relazione tra Privacy e Security?

Privacy e **Security** sono concetti correlati ma distinti:
Security (Sicurezza):

- Riguarda la **protezione dei dati da accessi non autorizzati**.
- Si occupa di garantire: *confidenzialità* (solo chi è autorizzato accede), *integrità* (i dati non vengono alterati), *disponibilità* (i dati sono accessibili quando necessario).
- Strumenti: crittografia, firewall, autenticazione, controllo degli accessi (RBAC, ABAC).
- Focus: **proteggere il sistema** dagli attaccanti.

Privacy:

- Riguarda il **controllo sull'uso delle informazioni personali**, anche da parte di chi ha accesso autorizzato.
- Si occupa di: uso appropriato dei dati, consenso, minimizzazione, anonimizzazione.
- Strumenti: k-anonymity, differential privacy, pseudonimizzazione, SDC.
- Focus: **proteggere gli individui** da un uso improprio dei loro dati.

Relazione: la security è *necessaria ma non sufficiente* per la privacy.

- Un sistema può essere sicuro ma violare la privacy (es. un ospedale che ha la sicurezza delle reti ma vende i dati dei pazienti).
- La privacy richiede la security come fondamento, ma va oltre.

Nel contesto del GDPR, entrambe sono richieste: il controllore deve implementare misure di sicurezza adeguate (Art. 32) e rispettare i principi di Privacy by Design e by Default (Art. 25).

La crittografia su colonne, il Randomized Response e i sistemi di controllo degli accessi (ABAC/RBAC) sono strumenti che servono sia la security che la privacy.

Come lo spiegherei a voce

Il modo più semplice per ricordare la differenza è pensare a *chi* vogliono proteggere. La security protegge il sistema dagli attaccanti esterni: vuole impedire che chi non è autorizzato entri. La privacy protegge invece l'individuo anche da chi è autorizzato: un dipendente di un ospedale può avere accesso legittimo ai dati medici (quindi nessuna violazione di security), ma se li usa o li vende per uno scopo diverso da quello per cui erano stati raccolti, viola comunque la privacy del paziente. Per questo si dice che la security è necessaria ma non sufficiente: un sistema può essere tecnicamente sicurissimo e comunque violare sistematicamente la privacy delle persone che lo usano.

4 Privacy: Perché è Importante?

Domanda 4: Privacy: perché è importante?

Spiegare perché la privacy è importante, con riferimento a fonti teoriche e casi concreti.

La privacy è importante per molteplici ragioni:

1. Sentimenti individuali e dignità: La perdita della privacy crea un senso di disagio (“non confortabile”). I dati possono essere usati in modo improprio (furto d'identità). Stefano Rodatà lega la privacy alla **dignità umana**: la perdita dei dati personali ha un costo immenso (1.000–3.000\$ per cittadino).

2. Esigenze aziendali: Le aziende devono proteggere la reputazione, far sentire i clienti al sicuro, evitare dispute legali e rispettare le leggi.

3. Libertà civile e democrazia: Come dice Edward Snowden: *“Argumentare che non ci importa della privacy perché non abbiamo nulla da nascondere è come dire che non ci importa della libertà di espressione perché non abbiamo nulla da dire.”*

4. Evidenza empirica – casi concreti:

- **Netflix Prize (2006):** dati di rating “anonimizzati” re-identificati con probabilità 90%.
- **AOL (2006):** query di ricerca “anonimizzate” permettono di identificare gli utenti.
- **Cambridge Analytica (2018):** dati di 87 milioni di utenti Facebook usati per manipolare elezioni politiche.
- **Studio PNAS 2013:** i “Like” di Facebook rivelano orientamento sessuale, opinioni politiche, salute.
- **Sweeney (2001):** l'87% degli americani è unicamente identificabile da {ZIP, sesso, data di nascita}.
- **INPS data breach (2020):** hackers italiani accedono ai dati dell'INPS durante la pandemia.

5. Trade-off privacy-comodità: Più comodità spesso significa meno privacy (GPS, cookies, social network). Ma questo trade-off è in parte frutto di **ignoranza e conformismo**: con le tecniche giuste (DP, k-anonymity) è possibile ottenere sia utilità dei dati che protezione della privacy.

Come lo spiegherei a voce

Se devo argomentare a voce perché la privacy conta, il punto di partenza più efficace è smontare l'obiezione più comune: “non ho nulla da nascondere”. Snowden risponde che è come dire “non mi importa della libertà di parola perché non ho niente da dire” – confonde l'assenza di qualcosa da nascondere con l'assenza del diritto al controllo sulle proprie informazioni. Poi si può rincarare con i casi concreti: Netflix e AOL mostrano che anche dati “anonimizzati” permettono di risalire alle persone con tecniche relativamente semplici; Cambridge Analytica mostra che dati raccolti per un gioco innocuo possono finire per manipolare un'elezione. Il filo comune di tutti questi casi è che la perdita di controllo sui propri dati ha conseguenze concrete e spesso irreversibili, non solo un disagio astratto.

5 GDPR: Principi e Sanzioni

Domanda 5 & 14: GDPR – Principi, Sanzioni e Novità rispetto alla Direttiva

Descrivere il GDPR: principi fondamentali, sanzioni, novità rispetto alla Direttiva 95/46/EC, differenze con paesi extra-UE (USA).

Il **GDPR** (Regolamento EU 2016/679) è un **regolamento** (non direttiva) adottato il 27 aprile 2016, applicabile dal 25 maggio 2018. Non richiede leggi nazionali di recepimento.

Principi fondamentali (ereditati e rafforzati dalla Direttiva):

1. **Trasparenza:** il soggetto deve dare *consenso chiaro ed esplicito*; ha diritto di accedere facilmente ai propri dati.
2. **Scopo Legittimo:** i dati possono essere trattati solo per scopi specificati e non ulteriormente elaborati in modo incompatibile.
3. **Proporzionalità:** i dati devono essere accurati, aggiornati, e non mantenuti più del necessario.

Novità del GDPR rispetto alla Direttiva 95/46/EC:

- **Nuovi diritti:** diritto all'oblio (right to be forgotten), portabilità dei dati, diritto di opporsi al profiling.
- **Definizioni ampliate:** “dati personali” ora include location data, online identifier, dati genetici.
- “Trattamento” ora include structuring (strutturazione) e restriction (limitazione).
- **Pseudonimizzazione:** definita esplicitamente; se adeguata $\Rightarrow$ dati non soggetti a GDPR.
- **Privacy by Design e by Default:** obbligo formale (Art. 25).
- **Data Protection Officer (DPO):** figura obbligatoria per certi tipi di organizzazioni.
- **Data Protection Impact Assessment (DPIA):** obbligatorio per trattamenti ad alto rischio.
- **Data breach notification:** entro 72 ore all'autorità di supervisione.
- **Sanzioni molto più severe:** fino al 4% del fatturato mondiale.
- **Regolamento direttamente applicabile:** nessuna legge di recepimento nazionale necessaria.

Sanzioni GDPR:

- Prima violazione non intenzionale: **avviso**.
- Violazione di obblighi minori: fino a **10 milioni di euro** o **2% del fatturato mondiale**.
- Violazione grave dei principi: fino a **20 milioni di euro** o **4% del fatturato mondiale**.

Differenze EU vs. USA:

- Negli USA **non esiste una legge unificata** sulla data privacy: HIPAA (sanità), COPPA (minori), FCRA (credito), ECPA (comunicazioni), PATRIOT Act (sorveglianza). Le aziende che raccolgono dati (anche senza consenso) hanno il diritto di usarli.
- In UE la privacy è un **diritto fondamentale** (ECHR Art.8); il GDPR si applica a tutte le organizzazioni che trattano dati di cittadini UE, ovunque nel mondo.
- Accordi transatlantici per trasferimento dati: Safe Harbor (1998–2015) → EU-US Privacy Shield (2016–2020) → EU-US Data Privacy Framework (2023).

L'AI Act (2024): complementare al GDPR, classifica i sistemi di IA in 4 livelli di rischio (inaccettabile, alto, limitato, minimo).

Come lo spiegherei a voce

Per raccontare il GDPR senza limitarsi a elencare gli articoli, conviene partire dall'idea di fondo: prima della Direttiva del '95 ogni paese europeo aveva le sue regole, e con il GDPR si è passati a un regolamento unico, direttamente applicabile in tutta l'UE senza bisogno di leggi nazionali – questa è già di per sé la novità più importante. Le altre novità si spiegano bene come “risposte a problemi emersi nella pratica”: i nuovi diritti (oblio, portabilità) nascono perché gli utenti si sono accorti di non avere controllo sui propri dati una volta condivisi; l'obbligo di accountability nasce perché prima bastava essere conformi, ora bisogna anche poterlo *dimostrare* con la documentazione; le sanzioni salite fino al 4% del fatturato mondiale servono a rendere la compliance economicamente più conveniente della violazione, soprattutto per le grandi aziende per cui multe piccole sarebbero solo un costo di esercizio. Il confronto con gli USA è utile per far capire che l'approccio europeo (un diritto fondamentale, applicato a chiunque tratti dati di cittadini UE ovunque nel mondo) è l'eccezione, non la norma: gli USA hanno leggi settoriali (sanità, minori, credito) ma nessuna legge generale.

6 Discriminazione (Fairness)

Domanda 6: Discriminazione (parte su Fairness)

Cos'è la discriminazione? Che tipi esistono? Come si relaziona con i sistemi algoritmici?

Definizione: Discriminazione Diretta

La pratica di trattare in modo **diverso** le persone in base alla loro appartenenza a un gruppo sociale rilevante (razza, genere, religione, orientamento sessuale, età, etc.). Nell'UE è disciplinata dall'Art. 21 della Carta dei Diritti Fondamentali.

Definizione: Discriminazione Indiretta

La pratica di offrire lo **stesso trattamento** a persone appartenenti a gruppi distinti, quando questo comporta che un gruppo sia posto in una situazione di particolare svantaggio.

Esempi:

- *Discriminazione indiretta*: le pensioni calcolate ugualmente per part-time e full-time penalizzano le donne (88% dei part-time) $\Rightarrow$ effetto sproporzionatamente negativo (caso Hilde Schönheit vs. Stadt Frankfurt am Main).
- *Discriminazione indiretta sistemica*: test di intelligenza standardizzati per studenti Rom in Repubblica Ceca, concepiti per la popolazione generale ceca $\Rightarrow$ 50-90% dei bambini Rom fuori dal sistema scolastico tradizionale (caso D.H. vs. Repubblica Ceca).

Cosa rende sbagliata la discriminazione?

1. *Animosità sistematica (intento ostile)*: tradizionalmente la base per definire la discriminazione. Ma: gli algoritmi non hanno intenzioni; gli scienziati possono affermare di non aver avuto intenzioni discriminatorie.
2. *Fare inferenze sugli individui basate sui gruppi*: trattare le persone come rappresentanti di categorie invece che come individui.

Discriminazione algoritmica: i sistemi ML ereditano (e amplificano) i bias presenti nei dati di training.

- Google Photos classifica afroamericani come gorilla.
- COMPAS: sistema di predizione della recidiva criminale assegna punteggi di rischio più alti ad afroamericani.
- Amazon recruitment model: discrimina le donne (le candidature con curricula femminili ricevono punteggi minori).
- Negli USA, candidati con nomi “bianchi” ricevono il 50% in più di colloqui di lavoro.

Tipi di danni algoritmici:

- **Allocativi**: risorse negate disparatamente (prestiti, assunzioni, libertà provvisoria).
- **Rappresentativi**: subordinazione rafforzata (ricerca di immagini, traduzione automatica).

Come lo spiegherei a voce

L'idea chiave da comunicare è che la discriminazione **indiretta** è più insidiosa di quella diretta, perché non richiede nessuna intenzione cattiva: basta trattare tutti allo stesso modo quando le condizioni di partenza sono già diverse. L'esempio delle pensioni part-time/full-time è perfetto per questo: la regola è formalmente identica per tutti, ma siccome la maggioranza dei part-time erano donne, l'effetto pratico è discriminatorio anche senza che nessuno l'abbia voluto. Questo è importante per la fairness algoritmica perché un algoritmo non ha intenzioni – quindi se ci basiamo solo sul criterio dell'intento ostile, nessun algoritmo potrebbe mai essere giudicato discriminatorio, il che è chiaramente sbagliato visti i casi reali (COMPAS, Amazon). Bisogna quindi giudicare gli *effetti*, non le intenzioni.

7 Teoremi di Incompatibilità: Separazione e Sufficienza

Domanda 7: Teoremi di Incompatibilità: Separazione e Sufficienza

Enunciare e spiegare i teoremi di incompatibilità tra i criteri di fairness.

Siano X covariate, Y variabile target (ground truth), $\hat{Y}$ predizione del classificatore, A attributo sensibile (es. razza, genere).

Tre criteri principali di fairness:

1. Indipendenza (Demographic Parity): $\hat{Y} \perp A$

$$\mathbb{P}(\hat{Y} = 1 \mid A = a) = \mathbb{P}(\hat{Y} = 1 \mid A = b)$$

Ogni gruppo riceve la stessa percentuale di esiti positivi.

2. Separazione (Equal Error Rates): $\hat{Y} \perp A \mid Y$

Il classificatore commette errori con la stessa frequenza nei vari gruppi. Può essere intesa come parità dei tassi di errore tra i gruppi.

3. Sufficienza (Calibration): $Y \perp A \mid \hat{Y}$

La previsione del modello è ugualmente affidabile (calibrata) per tutti i gruppi.

Teoremi di Incompatibilità:

Teorema di Impossibilità (Chouldechova, 2017; Kleinberg et al., 2016)

Se A e Y **non sono indipendenti** (cioè il tasso base ($P(Y = 1)$) differisce tra i gruppi), allora:

- 1. Separazione e Indipendenza non possono essere entrambe soddisfatte** simultaneamente (eccetto in casi degeneri).
- 2. Sufficienza e Indipendenza non possono essere entrambe soddisfatte** simultaneamente (eccetto in casi degeneri).

Interpretazione intuitiva: Se il tasso base è diverso tra i gruppi (es. il gruppo A ha storicamente più recidiva del gruppo B), allora un classificatore calibrato avrà necessariamente tassi di errore diversi tra i gruppi (viola separazione), e viceversa.

Implicazione pratica: Non esiste un classificatore “perfetto” in termini di fairness quando i gruppi hanno tassi base diversi. Bisogna scegliere quale criterio privilegiare in base al contesto etico e legale.

Esempio COMPAS: un sistema calibrato (sufficienza: la previsione ha lo stesso significato per bianchi e neri) avrà necessariamente tassi di falsi positivi diversi tra i gruppi se i tassi di recidiva base sono diversi (viola separazione). Non è possibile avere entrambi.

Interventi di fairness:

- **Pre-processing:** modificare i dati di input X o i target Y .
- **In-processing:** vincoli o penalizzazioni durante il training.
- **Post-processing:** modificare $\hat{Y}$ dopo il training.

Come lo spiegherei a voce

Il punto più difficile da far capire a voce è perché questi tre criteri siano davvero incompatibili tra loro, e non solo “difficili da ottenere insieme”. Il ragionamento intuitivo è questo: se due gruppi hanno tassi di base diversi (per esempio il gruppo A ha storicamente più recidiva del gruppo B , magari per ragioni socioeconomiche), allora un modello calibrato correttamente per entrambi i gruppi (sufficienza) finirà inevitabilmente per commettere errori con frequenza diversa nei due gruppi (violando la separazione) – perché la calibrazione si basa proprio sulle proporzioni reali, che sono diverse. Non è un limite tecnico degli algoritmi attuali: è una conseguenza matematica che vale per qualunque classificatore, anche quello perfetto. Per questo non si parla di “trovare l'algoritmo giusto” ma di scegliere consapevolmente quale criterio di equità privilegiare nel contesto specifico.

8 Algoritmi per la K-Anonymity: Samarati e Incognito

Domanda 8 & 20: K-Anonymity e Algoritmi

Definire la k -anonymity e descrivere gli algoritmi di Samarati e Incognito.

Il problema: Latanya Sweeney (2001) re-identifica record medici del governatore del Massachusetts incrociando dati medici anonimizzati con la lista elettorale usando {ZIP code, sesso, data di nascita} come quasi-identificatori. L'87% degli americani è unicamente identificabile da questi tre attributi.

Definizione: K-Anonymity – Samarati & Sweeney, 1998

Un dataset T su attributi $A = a_1, \dots, a_n$ soddisfa la k -anonymity se e solo se per ogni combinazione di valori di quasi-identificatori in T , tale combinazione appare almeno k volte. Ogni individuo si nasconde in $k - 1$ altri individui; la confidenza di un linking attack è $\leq 1/k$.

Tecniche:

- **Generalizzazione:** valori sostituiti con valori più generali (ZIP 10149 $\rightarrow$ 101 * *).
- **Soppressione:** rimozione di tuple outlier che non possono essere generalizzate.

Domain Generalization Hierarchy (DGH): ordine parziale sui domini di un attributo. Il prodotto cartesiano di tutte le DGH forma un **reticolo di generalizzazione**.

Il problema di trovare la generalizzazione minimale è **NP-hard**.

Algoritmo di Samarati: Effettua una **ricerca binaria** sull'altezza del reticolo:

1. Valuta tutte le soluzioni ad altezza $h/2$.
2. Se esiste almeno una soluzione k -anonima: scendi a $h/4$; altrimenti sali a $3h/4$.
3. Ripeti fino a trovare l'altezza minima con una soluzione k -anonima con $\leq \text{MaxSup}$ soppressioni.

Proprietà: salendo nella gerarchia il numero di soppressioni necessarie diminuisce. Approccio branch-and-bound.

Algoritmo Incognito: Sfrutta la **monotonicità** della k -anonymity: se $QI' \subseteq QI$, la k -anonymity su QI' è condizione necessaria per la k -anonymity su QI .

Approccio **bottom-up** nel reticolo:

1. Iterazione 1: controlla la k-anonymity per ogni singolo attributo in QI ; scarta le generalizzazioni che non la soddisfano.
2. Iterazione 2: combina i rimanenti in coppie e controlla.
3. Iterazione i : combina tutte le i -uple.
4. Iterazione $|QI|$: risultato finale.

Limitazioni della k-anonymity:

- **Homogeneity attack**: se tutte le tuple in un blocco hanno lo stesso valore sensibile, la k-anonymity non protegge.
- **Background knowledge attack**: la conoscenza pregressa permette di inferire informazioni.
- **Curse of Dimensionality** (Aggarwal, VLDB 2005): con molti quasi-identificatori la k-anonymity richiede una generalizzazione eccessiva.

Come lo spiegherei a voce

Il caso Sweeney è il modo più efficace per spiegare perché serve la k-anonymity: tre dati che sembrano innocui (CAP, sesso, data di nascita) bastano da soli a identificare quasi chiunque, perché combinati diventano quasi unici. La k-anonymity risponde imponendo che ogni combinazione di questi quasi-identificatori compaia almeno k volte nel dataset rilasciato – così un attaccante può al massimo restringere il campo a k persone, non identificarne una sola. Gli algoritmi di Samarati e Incognito risolvono lo stesso problema (trovare la generalizzazione minima che basta a raggiungere la k-anonymity) con due strategie opposte: Samarati fa una specie di ricerca binaria sui livelli di generalizzazione, sfruttando il fatto che se un livello basta, bastano anche tutti i livelli più generalizzati di quello (quindi non serve controllarli uno per uno); Incognito invece parte dal basso, controllando prima un attributo alla volta e scartando subito le combinazioni che falliscono già da sole, perché se un sottoinsieme di attributi fallisce, qualsiasi sovrainsieme fallirà a sua volta – è la stessa logica dell'algoritmo Apriori nel data mining.

9 Laplace e Gauss (per Numerici), Esponenziale (per Categorici)

Domanda 10: Meccanismi Laplace, Gauss, Esponenziale

Descrivere i meccanismi di Laplace, Gaussiano ed Esponenziale per la Differential Privacy.

Meccanismo di Laplace (per query numeriche, ϵ -DP):

$$\mathcal{M}_{Lap}(D, q) = q(D) + Lap\left(0, \frac{GS_1(q)}{\epsilon}\right)$$

$GS_1(q) = \max_{D \sim D'} \|q(D) - q(D')\|_1$ (sensibilità L1). PDF: $f(x) = \frac{\epsilon}{2GS_1} e^{-\epsilon|x-q(D)|/GS_1}$.

Proprietà: Preserva ϵ -DP per qualsiasi $\epsilon > 0$. Meno rumore (migliore utilità) quando la sensibilità L1 è piccola. Ideale per query scalari e vettoriali con $GS_2 \approx GS_1$.

Meccanismo Gaussiano (per query vettoriali, (ϵ, δ) -DP):

$$\mathcal{M}_{Gauss}(D, q) = q(D) + \mathcal{N}(0, \sigma^2), \quad \sigma^2 = \frac{2 \cdot GS_2(q)^2 \cdot \ln(1.25/\delta)}{\epsilon^2}$$

$GS_2(q) = \max_{D \sim D'} \|q(D) - q(D')\|_2$ (sensibilità L2). Preserva (ϵ, δ) -DP per $\epsilon, \delta \in (0, 1)$.

Confronto Laplace vs. Gaussiano:

Aspetto	Laplace	Gaussiano
Tipo di DP	ε -DP	(ε, δ) -DP
Sensibilità	L1 (GS_1)	L2 (GS_2)
Vincolo su ε	Qualsiasi $\varepsilon > 0$	Richiede $\varepsilon < 1$
Quando preferire	Sempre disponibile	$GS_2 \ll GS_1$ (query ad alta dimensione)

Entropia: Gaussiano ha $H = \frac{1}{2} \log(2\pi e \sigma^2)$; Laplace ha $H = \ln(\sqrt{2}e\sigma)$. Il Gaussiano ha entropia minore (meno rumore) a parità di σ .

Meccanismo Esponenziale (per query categoriche):

Per query il cui output è un elemento r da un insieme categorico R (es. selezionare il candidato migliore), dove non ha senso aggiungere rumore numerico.

Sia $U : \Omega \times R \rightarrow \mathbb{R}$ una funzione di utilità e $GS(U) = \max_{r, D \sim D'} |U(D, r) - U(D', r)|$.

$$P(\mathcal{M}(D, q) = r) \propto \exp\left(\frac{\varepsilon \cdot U(D, r)}{2 \cdot GS(U)}\right)$$

L'output più utile viene selezionato con probabilità proporzionalmente più alta; preserva la DP con parametro $\varepsilon/2$ (o ε a seconda della formulazione).

Come lo spiegherei a voce

Il filo conduttore tra questi tre meccanismi è che ognuno risponde a un limite del precedente. Laplace è il meccanismo di base per query numeriche: aggiunge rumore calibrato sulla sensibilità della query, e funziona benissimo finché la sensibilità è semplice da misurare con la distanza L1. Quando invece le query restituiscono vettori (più numeri insieme) e la sensibilità euclidea (L2) è molto più piccola di quella L1, conviene passare al Gaussiano, che però paga il prezzo di una garanzia leggermente più debole, l' (ε, δ) -DP invece della ε -DP pura – in pratica si accetta una probabilità piccola δ di “fallimento” della garanzia, in cambio di meno rumore. L'Esponenziale infine serve per un caso completamente diverso: quando la risposta non è un numero ma una scelta tra alternative (es. quale candidato assumere), dove aggiungere rumore numerico non avrebbe senso – qui si campiona casualmente tra le alternative, ma pesando le probabilità in modo che le scelte migliori siano molto più probabili di quelle pessime.

10 Bias per Discriminazione e Apprendimento (Fairness)

Domanda 11: Concetto di Bias per Discriminazione e Apprendimento

Cos'è il bias in ML? Come si manifesta e perché porta alla discriminazione?

Bias nel Machine Learning: tendenza sistematica del modello a produrre errori sistematici in favore o contro certi gruppi.

Fonti di bias nel ciclo ML:

1. Bias nei dati di training (data bias):

- *Historical bias*: i dati riflettono pregiudizi storici (es. le donne erano sottorappresentate nei curricula di ingegneria).
- *Representation bias*: alcuni gruppi sono sottorappresentati nel dataset (insufficienti dati per certe etnie).
- *Measurement bias*: le misurazioni stesse sono parziali (es. lo stesso reato è registrato diversamente per diverse etnie).

2. Bias nell'apprendimento:

- *Inductive bias*: le assunzioni dell'algoritmo di learning (es. linearità) possono non adattarsi ugualmente bene a tutti i gruppi.
- Il modello può imparare correlazioni spurie tra attributi innocui e attributi sensibili (*proxy attributes*).

3. Bias nel deployment:

- Le azioni del modello cambiano il mondo (feedback loop): un modello che discrimina può creare dati futuri che confermano la discriminazione (self-fulfilling prophecy).

Problema dell'opacità: L'IA attuariale (ML) è spesso opaca – è difficile capire perché un sistema ha preso una particolare decisione. Anche ispezionando i parametri, è difficile collegare questi alle ragioni effettive delle decisioni.

Il paradosso dell'inconsapevolezza: Non usare esplicitamente l'attributo sensibile A (etnia, genere) non garantisce fairness, perché altri attributi possono essere fortemente correlati con A e il modello li userà implicitamente come proxy.

Esempi di bias algoritmico:

- COMPAS: bias razziale nei punteggi di rischio di recidiva.
- Amazon recruitment: downgrade dei curricula con parole associate alle donne.
- Riconoscimento facciale: errori più frequenti per donne e persone di colore.
- Traduzione automatica (Google Translate): introduce stereotipi di genere.

Come lo spiegherei a voce

Il modo più utile di organizzare questa risposta a voce è seguire il ciclo di vita del modello: il bias può entrare nei **dati** (prima ancora di iniziare il training, perché i dati storici riflettono già discriminazioni passate, o perché alcuni gruppi sono sottorappresentati), nell'**apprendimento** (l'algoritmo fa assunzioni che funzionano meglio per alcuni gruppi che per altri, o impara a usare attributi proxy anche senza che gli sia stato detto esplicitamente quale sia l'attributo sensibile), e nel **deployment** (le decisioni del modello cambiano il mondo reale, e i nuovi dati che si generano confermano e rafforzano il bias di partenza – un ciclo che si autoalimenta). Il punto dell'inconsapevolezza è cruciale: molti pensano che basti “non guardare” la razza o il genere per essere equi, ma se il codice postale o il nome sono già fortemente correlati con quegli attributi, il modello li userà comunque come proxy, anche senza che nessuno glielo abbia detto esplicitamente.

11 Trade-off Privacy-Utilità. KL e JS

Domanda 12: Trade-off Privacy-Utilità. KL e JS

Discutere il trade-off tra privacy e utilità dei dati, con riferimento alle divergenze KL e JS.

Il trade-off fondamentale: più si protegge la privacy di un dataset, meno informazioni utili rimangono. Non è possibile avere allo stesso tempo massima privacy e massima utilità.

Nel ciclo SDC: Data $\rightarrow$ Metodo SDC $\rightarrow$ Misura di Utilità + Misura di Rischio $\rightarrow$ iterazione. Si cerca un punto di compromesso: i dati rilasciati hanno rischio di disclosure accettabile con massima utilità residua.

Misure di utilità per macrodata: numero di soppressioni, somma delle distanze tra valori veri e perturbati.

Misure di utilità per microdata: quanto l'SDC ha cambiato l'output delle analisi; statistiche di base (medie, varianze, covarianze); **divergenze KL e JS**.

Kullback-Leibler (KL) Divergence

Misura quanto la distribuzione perturbata $P(x)$ è diversa da quella originale $Q(x)$:

$$KL(P\|Q) = \sum_{x \in X} P(x) \log \left(\frac{P(x)}{Q(x)} \right)$$

Proprietà: $KL(P\|Q) \geq 0$; $KL(P\|Q) = 0$ iff $P = Q$; **non è simmetrica**.

Jensen-Shannon (JS) Divergence

Versione simmetrica e smoothed di KL:

$$JS(P\|Q) = \frac{1}{2}KL(P\|M) + \frac{1}{2}KL(Q\|M), \quad M = \frac{P+Q}{2}$$

Proprietà: simmetrica ($JS(P\|Q) = JS(Q\|P)$); $0 \leq JS \leq 1$; sempre definita (nessun problema con probabilità zero).

Utilizzo nel trade-off: KL/JS misurano quanto la distribuzione dei dati protetti si discosta da quella originale. Un $JS \approx 0$ indica alta utilità (le distribuzioni sono simili); un $JS \approx 1$ indica bassa utilità.

Nella Differential Privacy: il Meccanismo di Laplace aggiunge rumore calibrato a GS/ϵ . Maggiore è il rumore (piccolo ϵ), maggiore la privacy ma minore l'utilità.

Come lo spiegherei a voce

Il concetto da portare a voce è che privacy e utilità sono in tensione strutturale, non per un limite tecnico che si potrà superare in futuro: più nascondo informazione su un individuo, meno informazione utile resta nei dati aggregati, è una conseguenza quasi logica. KL e JS sono semplicemente due modi per misurare quanto questa distanza tra "i dati veri" e "i dati protetti" sia grande: se la divergenza è quasi zero, vuol dire che ho protetto la privacy senza sacrificare molta utilità; se è vicina al massimo, vuol dire che ho distrutto l'informazione. La differenza pratica tra le due: KL non è simmetrica (la distanza da P a Q non è la stessa che da Q a P) e può esplodere a infinito se una distribuzione ha probabilità zero dove l'altra non l'ha; JS risolve entrambi i problemi mediando le due distribuzioni, quindi è più comoda da usare come metrica pratica.

12 Uso di XML per RBAC e ABAC

Domanda 13: Uso di XML per RBAC e ABAC

Come si usano XML e XACML per implementare il controllo degli accessi RBAC e ABAC?

RBAC (Role Based Access Control, NIST 1992): gestione dell'accesso tramite ruoli. Gli amministratori assegnano permessi ai ruoli; i ruoli vengono assegnati agli utenti. **Limite:** non cattura il contesto (scope, finalità, ambiente).

ABAC (Attribute Based Access Control): evoluzione di RBAC. Le decisioni si basano su attributi di soggetto (chi è), oggetto (a cosa accede), e ambiente (quando, dove, come). Approccio policy-driven.

XACML (eXtensible Access Control Markup Language): standard XML per esprimere policy di accesso in ABAC.

Architettura ABAC con XACML:

- **PEP** (Policy Enforcement Point): riceve la richiesta di accesso e la invia al PDP.
- **PDP** (Policy Decision Point): valuta le policy XACML e decide (Permit/Deny).
- **PAP** (Policy Administration Point): amministra e archivia le policy.
- **PIP** (Policy Information Point): recupera attributi aggiuntivi necessari per la valutazione.

Algoritmi di combinazione in XACML:

- **Permit-overrides**: se almeno una policy dice Permit $\Rightarrow$ risultato = Permit.
- **Deny-overrides**: se almeno una policy dice Deny $\Rightarrow$ risultato = Deny (più restrittivo).

Crittografia su Colonne (complemento al controllo degli accessi): cifra i dati a livello di colonna nel database.

- *Column encryption keys*: cifrare il dato.
- *Column master keys*: cifrare le encryption keys (in repository esterno).
- *Deterministica*: stessa chiave $\rightarrow$ stesso ciphertext (permette ricerche, meno sicura).
- *Randomizzata*: valori casuali (più sicura, impedisce ricerche dirette).

Come lo spiegherei a voce

La cosa da far emergere parlando è il limite di RBAC che porta naturalmente ad ABAC: RBAC dice solo “che ruolo hai”, ma non “in che contesto stai chiedendo l’accesso”. Un medico ha il ruolo di medico sempre, ma magari dovrebbe poter leggere la cartella clinica solo durante l’orario di lavoro, dal suo reparto, da un dispositivo aziendale – questo è esattamente ciò che ABAC aggiunge, valutando attributi del soggetto, della risorsa e dell’ambiente insieme, non solo il ruolo. XACML è semplicemente il linguaggio standard per scrivere queste regole in un formato che un motore software può valutare automaticamente; l’architettura PEP/PDP/PAP/PIP separa chi fa la richiesta (PEP), chi decide (PDP), chi scrive le regole (PAP) e chi fornisce informazioni aggiuntive necessarie alla decisione (PIP) – un po’ come separare in un tribunale chi presenta il caso, chi giudica, chi scrive le leggi e chi fornisce le prove.

13 Privacy by Design e by Default

Domanda 15: Privacy by Design e by Default

Descrivere la Privacy by Design e by Default: concetto, origini, principi fondamentali.

Privacy by Design è un approccio proposto da **Ann Cavoukian** (2012), Commissaria per l’Informazione e la Privacy dell’Ontario, Canada. L’idea di base: la privacy non deve essere aggiunta a posteriori ai sistemi, ma deve essere **progettata e incorporata fin dall’inizio**.

Il GDPR (Art. 25) rende la Privacy by Design e by Default un **obbligo legale**.

7 Principi Fondamentali:

1. **Proattività, non reattività – Prevenzione, non rimedio:** anticipare e prevenire i problemi prima che si verifichino. Non aspettare le violazioni.
2. **Privacy come impostazione di Default:** senza azioni da parte dell'utente, le impostazioni più privacy-preserving devono essere quelle default. "Opt-out", non "opt-in".
3. **Privacy integrata nel Design:** la privacy fa parte integrante dell'architettura del sistema e dei processi di business, non è un'aggiunta.
4. **Full Functionality – positive-sum, non zero-sum:** privacy e funzionalità non si escludono mutualmente. Entrambe possono essere ottenute allo stesso tempo.
5. **End-to-end Security – protezione dell'intero ciclo di vita:** la sicurezza dei dati deve essere garantita dall'acquisizione alla cancellazione.
6. **Visibilità e Trasparenza – Keep it Open:** tutte le attività di trattamento devono essere visibili e verificabili da utenti e regolatori.
7. **Rispetto per la Privacy degli Utenti – Keep it User-Centric:** l'utente al centro. Le decisioni devono tenere conto delle sue preferenze e aspettative.

Privacy by Default nel GDPR:

- Raccogliere solo i dati strettamente necessari per ogni scopo specifico.
- Conservare i dati solo per il tempo necessario.
- Rendere i dati accessibili solo alle persone necessarie.

Responsibility e Accountability: il titolare del trattamento deve non solo rispettare la privacy, ma anche essere in grado di **dimostrare** la compliance. Questo include: mantenere registri delle attività di trattamento, condurre DPIA per trattamenti ad alto rischio, nominare un DPO quando necessario.

Come lo spiegherei a voce

Il punto centrale è che la Privacy by Design ribalta l'approccio tradizionale: di solito si costruisce prima un sistema e poi, se serve, si aggiunge la privacy come una toppa successiva; Cavoukian propone invece di pensare alla privacy fin dal primo schizzo dell'architettura, esattamente come si fa con la sicurezza. I 7 principi si possono raccontare come un percorso logico: si parte dall'essere proattivi invece che reattivi (prevenire, non rimediare), si passa per il fatto che la configurazione più protettiva deve essere quella di default (l'utente non deve fare nulla per essere protetto), e si arriva all'idea, forse la più importante da sottolineare, che privacy e funzionalità non sono in conflitto necessario (positive-sum, non zero-sum) – è un mito da sfatare che proteggere la privacy significhi sempre sacrificare l'utilità del sistema.

14 Cambridge Analytica

Domanda 16: Cambridge Analytica

Descrivere il caso Cambridge Analytica come esempio di uso dei dati per finalità diverse da quelle originarie.

Il caso Cambridge Analytica (2016–2018) è l'esempio paradigmatico di violazione del principio di *scopo legittimo*: dati raccolti per una finalità (divertimento, ricerca accademica) usati per un'altra (manipolazione politica).

Cronologia:

1. **2014**: Aleksandr Kogan, ricercatore dell'Università di Cambridge, crea un'app-quiz ("thisisyourdigitallife"). Circa 270.000 utenti la installano dando consenso a raccogliere i propri dati Facebook.
2. **API di Facebook (pre-2015)**: permetteva agli sviluppatori di accedere non solo ai dati degli utenti dell'app, ma anche a quelli dei loro **amici** senza consenso esplicito.
3. Risultato: Kogan raccoglie dati di circa **87 milioni di utenti** Facebook.
4. Kogan vende i dati a Cambridge Analytica (violando i termini di servizio di Facebook).
5. Cambridge Analytica usa i dati per costruire **profili psicologici** (basati sul modello OCEAN/Big Five) e mirare messaggi politici personalizzati.
6. I profili vengono usati nelle campagne di Donald Trump (2016) e nel referendum Brexit (2016).

Perché è possibile? – Studio PNAS 2013 (Kosinski et al.): analizzando i "Like" su Facebook con SVD + regressione logistica si può predire: orientamento sessuale (88% accuratezza), etnia (95%), opinioni politiche (85%), religione (82%), stato relazionale, uso di droghe. I "proxy attributes" (like a band, film) rivelano informazioni altamente sensibili.

Violazioni principali:

- **Scopo legittimo**: i dati raccolti per la ricerca usati per finalità politiche/commerciali.
- **Trasparenza e consenso**: nessun consenso degli 87 milioni; violazione dei ToS di Facebook.
- **Proporzionalità**: raccolta eccessiva di dati (dati degli amici senza consenso).

Conseguenze: sanzione di \$5 miliardi a Facebook dalla FTC; rafforzamento del GDPR; chiusura di Cambridge Analytica nel 2018.

Lezione: il principio del "nulla da nascondere" è ingenuo; dati apparentemente innocui (like musicali) possono essere usati per manipolazione su larga scala.

Come lo spiegherei a voce

Il filo narrativo più chiaro per raccontare questo caso è seguire la catena di scopi: i dati nascono per un quiz divertente, con il consenso degli utenti solo per quello scopo; ma una falla nell'API di Facebook permette di raccogliere anche i dati degli amici di chi aveva installato l'app, moltiplicando il numero di persone coinvolte da 270mila a 87 milioni senza che la stragrande maggioranza avesse mai dato un consenso; quei dati vengono poi rivenduti e usati per uno scopo completamente diverso, costruire profili psicologici per indirizzare propaganda politica personalizzata. È un caso da manuale di violazione del principio di scopo legittimo – il dato non era "al sicuro" tecnicamente (era su server protetti), ma è stato usato per qualcosa che nessuno aveva autorizzato. Lo studio di Kosinski sui Like di Facebook spiega perché questo era possibile: anche dati apparentemente innocui come i "mi piace" a una pagina musicale permettono di predire con alta accuratezza tratti molto sensibili come l'orientamento sessuale o le opinioni politiche, perché funzionano come proxy attributes.

15 Principi Crittografici nel Corso

Domanda 17: Principi Crittografici durante il Corso

Descrivere i principi crittografici trattati nel corso.

1. Crittografia a Chiave Pubblica (RSA):

- Ogni utente ha una coppia di chiavi: **pubblica** (per cifrare) e **privata** (per decifrare).
- Basata sulla difficoltà di fattorizzare il prodotto di due numeri primi grandi.
- Chiunque può cifrare con la chiave pubblica; solo il possessore della privata può decifrare.
- Usa anche un sistema di padding per sicurezza.

2. Crittografia su Colonne (Column-Level Encryption):

- Column encryption keys (per i dati) + Column master keys (per le encryption keys, conservate esternamente).
- Deterministica vs. randomizzata.
- TDE (Oracle): Transparent Data Encryption con Oracle Wallet come repository esterno.

3. Oblivious Transfer (OT) – Principio Crittografico per SMC:

- OT 1-of-2: il receiver ottiene esattamente uno dei due messaggi del sender; il sender non sa quale.
- OT 1-of-N: estensione usando funzioni pseudo-randomiche.
- Oblivious Polynomial Evaluation: il receiver ottiene $Q(z)$ senza che il sender sappia z .

4. Garbled Circuit (Yao):

- Tecnica per eseguire funzioni arbitrarie in modo sicuro tra due parti.
- Le tavole di verità dei gate del circuito sono cifrate (“garbled”).
- Il receiver valuta il circuito senza vedere i valori intermedi.

5. Crittografia Funzionale:

- Generalizzazione della crittografia a chiave pubblica.
- Decifrare rivela solo una funzione del plaintext (es. “è maggiore di 30?”).

6. Crittografia Omomorfica:

- Permette di effettuare calcoli sui dati cifrati senza decifrarli.
- I risultati sono in forma cifrata e decifrando si ottiene il risultato delle operazioni.
- Computazionalmente molto costosa.

7. Pseudoanonimizzazione:

- Sostituzione di informazioni identificabili con pseudonimi.
- Reversibile (con la chiave/tabella di mapping).

- Diversa dall'anonimizzazione totale.

Come lo spiegherei a voce

Per non recitare semplicemente una lista di sette tecniche, conviene raggrupparle per il problema che risolvono. RSA e la crittografia su colonne risolvono il problema classico: proteggere un dato cifrandolo, dove solo chi ha la chiave giusta può leggerlo. Oblivious Transfer e Garbled Circuit risolvono un problema diverso e più sottile: permettere a due parti di calcolare insieme qualcosa (es. chi è più ricco) senza che nessuna delle due riveli il proprio dato all'altra – qui non si tratta di nascondere un dato a terzi, ma di nascondere persino al proprio interlocutore di calcolo. Crittografia funzionale e omomorfica vanno oltre: permettono di calcolare su dati cifrati senza mai decifrarli, la prima rivelando solo il risultato di una funzione specifica, la seconda permettendo calcoli arbitrari (al prezzo di essere lentissima). La pseudoanonimizzazione infine è concettualmente diversa dalle altre: non è un meccanismo di calcolo sicuro, ma un modo di gestire i dati in modo che siano reversibili solo con una chiave/tabella separata.

16 L-Diversity e Differential Privacy

Domanda 18: L-Diversity e Differential Privacy

Confrontare la l-diversity con la differential privacy come protezioni contro gli attacchi alla k-anonymity.

Contesto: la k-anonymity non protegge contro homogeneity attack e background knowledge attack.

L-Diversity (Machanavajjhala et al., 2006): richiede che ogni q^* -block (classe di equivalenza) contenga almeno $l \geq 2$ valori sensibili *ben rappresentati*.

Formulazione tramite entropia:

$$-\sum_{s \in S} p(q^*, s) \log(p(q^*, s)) \geq \log(l)$$

Vantaggi: semplice da capire; soddisfa proprietà di monotonicità (compatibile con gli algoritmi per la k-anonymity).

Limiti della l-diversity:

- **Skewness attack:** se un valore sensibile è molto più comune nella popolazione, la sua presenza in un blocco l-diverso non protegge.
- **Similarity attack:** valori semanticamente simili (diversi tipi di cancro) non proteggono anche se formalmente diversi.
- Non modella esplicitamente la conoscenza dell'avversario.

Differential Privacy (Dwork, 2006): approccio fondamentalmente diverso.

Confronto:

Aspetto	L-Diversity	Differential Privacy
Tipo	Non-perturbativa o perturbativa	Perturbativa (rumore)
Garanzia	Per-block	Su tutto il dataset
Modello avversario	Implicito	Esplicito (qualsiasi KB)
Misurabilità	Parametro l	Parametro ϵ
Trade-off	Generalizzazione	Rumore
Robustezza	Limitata	Massima (teorema)

La DP offre garanzie molto più forti: indipendente dalla conoscenza pregressa dell'avversario; modello matematicamente rigoroso; garantisce che la risposta alla query non riveli più di quanto l'avversario già sapesse.

Oggi: la DP ha sostanzialmente rimpiazzato la l-diversity e la k-anonymity per la protezione di dati statistici. La k-anonymity rimane rilevante per la pubblicazione di microdata (non query).

Come lo spiegherei a voce

Il modo più chiaro di spiegare perché si è passati dalla l-diversity alla differential privacy è mostrare cosa la prima non riesce a fare: la l-diversity protegge ogni singolo blocco di dati assicurando che ci siano almeno l valori sensibili diversi, ma non dice nulla su cosa un attaccante con conoscenza esterna (background knowledge) possa dedurre comunque – per esempio se in un blocco ci sono solo malattie diverse ma quasi tutte rare tranne in un certo gruppo, l'attaccante può ancora indovinare con alta probabilità. La DP cambia completamente strategia: invece di proteggere blocchi di dati, mette un vincolo matematico sul meccanismo che genera le risposte, garantendo che valga sempre, indipendentemente da cosa l'attaccante sappia già. Questa è la ragione per cui oggi la DP ha sostanzialmente sostituito la l-diversity per il rilascio di statistiche tramite query – la k-anonymity e le sue varianti restano comunque utili quando bisogna pubblicare un intero microdata set (non rispondere a query), perché lì la nozione di “dataset adiacente” della DP non si applica altrettanto naturalmente.

17 Multiparty Secure Computation: Milionari, OT, ID3

Domanda 19 & 21: Multiparty Secure Computation: Milionari, Oblivious Transfer, ID3

Descrivere i protocolli di Secure Multiparty Computation trattati nel corso.

Problema: si vuole effettuare un'analisi congiunta su dati distribuiti tra parti che non si fidano l'una dell'altra.

SMC (Secure Multiparty Computation): calcolare una funzione quando ogni parte ha qualche input, senza che nessuna parte impari più di quanto l'output permette di inferire.

Il Problema dei Milionari (Yao)

Alice e Bob vogliono sapere chi è più ricco senza rivelare il proprio patrimonio.

Soluzione con Garbled Circuit:

1. Alice (garbler) crea un garbled circuit per la funzione di confronto $A > B$.
2. Alice invia il garbled circuit a Bob insieme ai garbled values corrispondenti al suo input A .
3. Bob usa **Oblivious Transfer** per ottenere i garbled values del suo input B senza che Alice sappia B .
4. Bob valuta il garbled circuit: solo l'output finale è rivelato.

La funzione di confronto binario si implementa con il circuito: $(A \oplus B) \cdot A$. XOR gate: calcolato localmente (gratuito). AND gate: tramite OT table.

Overhead: $O(\text{dimensione del circuito}) + O(|y|)$ OT. Solo 2 round di comunicazione.

Oblivious Transfer (OT)

OT 1-of-2: sender ha (x_0, x_1) ; receiver ha $\sigma \in \{0, 1\}$. Proprietà: receiver impara x_σ e niente altro; sender non impara σ .

OT 1-of-N: estensione tramite funzioni pseudo-randomiche: $c_{ij} = F_{k'_i}(ij) \oplus F_{k_j}(ij) \oplus m_{ij}$.

Oblivious Polynomial Evaluation: sender ha polinomio Q di grado k ; receiver ha z ; receiver ottiene $Q(z)$. Il sender non sa z ; il receiver non sa i coefficienti. Overhead: $O(k)$ esponenziali.

Privacy Preserving ID3 (Lindell & Pinkas, 2002)

ID3 Algorithm: costruisce un decision tree tramite information gain. Iterativamente seleziona l'attributo con massimo guadagno di informazione.

ID3_δ: protocollo per ID3 su dati orizzontalmente distribuiti tra due parti (semi-honest model).

Tre passi principali per costruire il decision tree:

1. **Classe più frequente:** calcolata con il protocollo di Yao (circuiti per trovare il massimo); necessario per decidere se creare una foglia.
2. **Verifica foglia (leaf check):** tramite protocollo di uguaglianza (ogni parte conta i propri record per ciascuna classe; si verifica se tutte le tuple appartengono alla stessa classe).
3. **Selezione del miglior attributo:** calcola $x \ln x$ per ogni valore dell'attributo usando una serie di Taylor: $\ln(1 + \varepsilon) \approx \varepsilon - \varepsilon^2/2 + \varepsilon^3/3 - \dots$; permette di calcolare l'entropia e il guadagno di informazione in modo privato.

Sicurezza del protocollo OT:

- Per il sender: un receiver corrotto non impara informazioni aggiuntive diverse dal messaggio che ha dichiarato di voler leggere.
- Per il receiver: un sender corrotto non impara nulla sul receiver.

Altri approcci per dati distribuiti:

- **Functional Encryption:** decifrare rivela solo $f(\text{plaintext})$.
- **Homomorphic Encryption:** calcoli su dati cifrati.
- **Federated Learning:** allenamento distribuito; solo i gradienti/parametri vengono condivisi, non i dati grezzi.

Come lo spiegherei a voce

Tutti questi protocolli risolvono la stessa domanda di fondo posta dal Problema dei Milionari: come calcolare insieme qualcosa senza che nessuno dei due riveli all'altro il proprio dato di partenza? La soluzione passa per il Garbled Circuit: si trasforma il problema in un circuito logico (XOR, AND), si cifra ogni gate del circuito in modo che produca il risultato corretto solo se si possiedono le chiavi giuste, e l'Oblivious Transfer è il meccanismo che permette a Bob di ottenere esattamente le chiavi che gli servono per il proprio input, senza che Alice scopra quale valore Bob abbia in realtà. ID3 privato applica esattamente questa stessa logica a un problema più complesso, costruire un albero decisionale: il problema tecnico in più è che il calcolo dell'information gain richiede un logaritmo, difficile da calcolare dentro un circuito sicuro, quindi si approssima con una serie di Taylor (un polinomio, fatto solo di somme e moltiplicazioni, che un circuito sicuro gestisce facilmente).

18 Bias: Rischi Etici e Misurazione (Fairness)

Domanda 22: Bias – Rischi Etici e Misurazione (Fairness)

Descrivere i rischi etici del bias algoritmico e i metodi per misurare la fairness.

Rischi Etici del Bias:

1. **Danni Allocativi**: risorse o opportunità vengono negate in modo disparato.

- **COMPAS**: punteggi di rischio di recidiva più alti per afroamericani $\Rightarrow$ detenzione preventiva ingiustificata.
- **Amazon**: modello di selezione del personale che discrimina le donne.
- **Credito**: algoritmi che negano prestiti a minoranze etniche.
- **Sanità**: algoritmi che allocano meno risorse sanitarie a certi gruppi.

2. **Danni Rappresentativi**: subordinazione e stereotipi rafforzati.

- **Ricerca di immagini**: ricerche come “professore” mostrano principalmente uomini bianchi.
- **Traduzione automatica**: introduzione di stereotipi di genere.
- **Riconoscimento facciale**: errori più frequenti per donne e persone di colore.

3. **Erosione della fiducia**: se i sistemi automatici sono percepiti come ingiusti, si riduce la fiducia nelle istituzioni che li usano.

4. **Effetti di feedback**: un sistema discriminatorio crea dati futuri che confermano la discriminazione (bias self-reinforcing).

5. **Mancanza di trasparenza**: i sistemi ML complessi (deep learning) sono difficili da interpretare; è difficile identificare e correggere il bias.

Misure di Fairness:

Siano A = attributo sensibile, Y = valore reale (ground truth), $\hat{Y}$ = previsione del classificatore.

Indipendenza (Demographic Parity): $\hat{Y} \perp A$

$$P(\hat{Y} = 1|A = a) = P(\hat{Y} = 1|A = b)$$

Ogni gruppo riceve la stessa percentuale di esiti positivi. **Limite**: può essere soddisfatta con meccanismi ingiusti.

Separazione (Equal Error Rates): $\hat{Y} \perp A | Y$

Parità del tasso di errore: il classificatore commette errori ugualmente frequenti in tutti i gruppi. Equivalente a:

- Equal True Positive Rate (TPR).
- Equal False Positive Rate (FPR).

Sufficienza (Calibration): $Y \perp A | \hat{Y}$

La previsione del modello ha lo stesso significato predittivo per tutti i gruppi.

Teoremi di Incompatibilità: se A e Y non sono indipendenti, **separazione e indipendenza** non possono essere entrambe soddisfatte; né **sufficienza e indipendenza**. La scelta del criterio di fairness dipende dal contesto etico.

Interventi di Fairness:

- **Pre-processing:** rimozione o de-biasing dei dati (soppressione di attributi proxy, re-weighting).
- **In-processing:** aggiungere vincoli di fairness durante il training (penalizzazioni nella funzione di loss).
- **Post-processing:** modificare le predizioni $\hat{Y}$ per soddisfare vincoli di fairness.

Ruolo dell'egalitarismo: da una prospettiva etica, le ineguaglianze dovute alla *fortuna* (nascere in un certo gruppo) dovrebbero essere corrette; quelle dovute al *merito* possono essere accettate. Ma distinguere fortuna da merito è difficile, e l'inconsapevolezza pura nei modelli ML è praticamente impossibile da garantire.

Come lo spiegherei a voce

Il modo migliore per organizzare questa risposta è distinguere chiaramente tra il danno immediato (**allocativo**: a chi viene negata una risorsa concreta, un prestito, un lavoro, la libertà provvisoria) e il danno più sottile ma altrettanto reale (**rappresentativo**: rafforzare stereotipi culturali, come quando una ricerca di immagini per “professore” mostra solo uomini bianchi). Il punto da sottolineare è l'effetto feedback loop: un sistema che discrimina non resta statico, perché le sue stesse decisioni generano nuovi dati che sembrano confermare il pregiudizio di partenza (se nego più prestiti a un gruppo, quel gruppo avrà statisticamente meno storia creditizia positiva, il che “giustificerà” future decisioni negative) – è un circolo vizioso che si autoalimenta nel tempo. Le tre metriche e la loro incompatibilità sono le stesse della Domanda 7: qui il punto in più è collegarle a un giudizio etico, distinguendo le ineguaglianze dovute alla fortuna (es. nascere in un quartiere povero) da quelle dovute al merito – una distinzione importante ma difficile da operationalizzare in un algoritmo.

19 Argomenti Aggiuntivi

Domanda 23: AI Act

Cos'è l'AI Act? Quali livelli di rischio definisce e quali obblighi impone a provider e deployer?

L'**AI Act** è il regolamento europeo sull'intelligenza artificiale, in vigore dal 1° agosto 2024, che mira a garantire che i sistemi di IA siano sicuri, trasparenti e rispettosi dei diritti fondamentali.

Classificazione a 4 livelli di rischio:

1. **Rischio inaccettabile – Vietati** (Art. 5): manipolazione subliminale del comportamento, sfruttamento di vulnerabilità di gruppi specifici, social scoring governativo, riconoscimento facciale di massa, dark-pattern IA.
2. **Alto rischio – Conformity Assessment** (Art. 6 e ss.): sistemi in sanità, istruzione, occupazione, giustizia, immigrazione, forze dell'ordine, infrastrutture essenziali. Richiedono valutazione rigorosa dei rischi, governance dei dati, supervisione umana, monitoraggio continuo.
3. **Rischio limitato – Trasparenza** (Art. 52): chatbot, deepfake, sistemi di riconoscimento delle emozioni. Obbligo di informare l'utente che sta interagendo con un sistema IA.
4. **Rischio minimo – Codice di condotta** (Art. 69): la maggior parte dei sistemi IA (videogiochi, filtri antispam). Praticamente non regolamentati, per favorire l'innovazione.

Obblighi per i modelli General Purpose AI (GPAI): fornire documentazione tecnica e istruzioni d'uso, rispettare la Direttiva Copyright UE, pubblicare un sommario dei dati di training, condurre valutazioni e test avversariali per modelli con rischi sistemici, garantire protezioni di cybersecurity.

Obblighi specifici:

- **Provider (sviluppatori):** implementare un sistema di gestione del rischio, garantire dataset di alta qualità, mantenere documentazione tecnica dettagliata, progettare sistemi con adeguati livelli di accuratezza, robustezza e cybersecurity.
- **Deployer (utenti):** usare i sistemi come previsto, monitorarne le prestazioni, garantire la supervisione umana per prevenire e mitigare i rischi.

Governance: l'AI Act istituisce l'**European Artificial Intelligence Board**, che supervisiona l'implementazione e garantisce un'applicazione coerente negli Stati Membri; le autorità nazionali competenti fanno rispettare la compliance nelle rispettive giurisdizioni.

Relazione con il GDPR: l'AI Act è complementare al GDPR – il GDPR regola il trattamento dei dati personali, l'AI Act regola il comportamento e i rischi dei sistemi di IA in quanto tali, indipendentemente dal fatto che trattino o no dati personali.

Come lo spiegherei a voce

Il modo più semplice di spiegare l'AI Act a voce è dire che applica all'IA la stessa logica di gestione del rischio che già conosciamo da altri settori regolamentati (farmaci, aviazione): non si vieta tutto, si classifica in base al danno potenziale. I casi vietati sono quelli che toccano direttamente diritti fondamentali in modo manipolatorio (subliminale, social scoring); l'alto rischio riguarda settori dove un errore ha conseguenze serie sulla vita delle persone (sanità, giustizia, lavoro) e richiede quindi controlli pesanti; il rischio limitato si accontenta della trasparenza (basta dire all'utente che sta parlando con un bot); il rischio minimo non viene quasi toccato, per non soffocare l'innovazione su cose come i videogiochi. È complementare al GDPR perché il GDPR si occupa di *cosa* si fa con i dati personali, mentre l'AI Act si occupa di *come* si comporta il sistema di IA, anche quando non tratta dati personali in senso stretto.

20 Digital Services Act (DSA)

Domanda 24: Digital Services Act (DSA)

Cos'è il Digital Services Act? Quali aree disciplina e come si differenzia dalla regolamentazione dei contenuti illegali?

Il **DSA** (2022) è un regolamento UE volto a creare uno spazio digitale più sicuro, dove i diritti fondamentali degli utenti siano protetti e venga stabilito un livello equo per le imprese. Principio chiave: *“ciò che è illegale offline deve essere illegale anche online.”*

Quattro aree principali (44 impegni, 128 misure):

- **Demonetizzazione:** riduzione degli incentivi finanziari per chi diffonde disinformazione.
- **Trasparenza della pubblicità politica:** etichettatura per riconoscere la pubblicità politica.
- **Integrità dei servizi:** riduzione di account fake, amplificazione tramite bot, deepfake malevoli e altri comportamenti manipolatori.

- **Fact-checking:** strumenti per identificare la disinformazione, accesso più ampio ai dati, copertura in tutta l'UE.

Distinzione fondamentale: il DSA **non** richiede la rimozione di contenuti legali ma dannosi (la disinformazione in senso lato); si concentra sui contenuti **illegali** (incitamento all'odio, merci contraffatte, pornografia infantile). Il meccanismo di segnalazione ("Notice and Action") impone alle piattaforme di fornire strumenti facili per segnalare contenuti illegali.

Obblighi di trasparenza: le piattaforme devono spiegare agli utenti perché un contenuto è stato rimosso o limitato, offrendo la possibilità di appello. Includono trasparenza sugli **algoritmi di raccomandazione**, trasparenza pubblicitaria, e **divieto di profilazione** basata su dati sensibili (orientamento sessuale, religione, etnia) o rivolta a minori.

Protezione dei minori: misure rafforzate per garantire alti livelli di privacy, sicurezza e riduzione dell'esposizione a contenuti inappropriati.

Sanzioni: ogni Stato Membro nomina un Coordinatore Nazionale per supervisionare la compliance; la Commissione Europea può imporre sanzioni fino al **6% del fatturato globale annuo**. Il DSA, insieme al Digital Markets Act (DMA), è la pietra angolare della strategia europea per un mercato digitale unico più sicuro.

Come lo spiegherei a voce

La frase guida del DSA è perfetta da ripetere a voce: "ciò che è illegale offline deve essere illegale online". Il punto sottile da far notare è che il DSA non vuole diventare un ministero della verità che decide cosa è vero o falso online: si occupa solo dei contenuti *già illegali* (incitamento all'odio, pedopornografia, merci contraffatte), lasciando la disinformazione "lecita ma dannosa" a strumenti più soft come la trasparenza algoritmica e il fact-checking. Per questo le piattaforme non sono obbligate a rimuovere tutto ciò che è fastidioso, ma devono spiegare le loro decisioni di moderazione e dare un meccanismo di appello – è un equilibrio tra proteggere la libertà di espressione e impedire abusi sistemici.

21 Data Act e Digital Omnibus

Domanda 25: Data Act e Digital Omnibus

Cos'è il Data Act? Cosa propone il Digital Omnibus rispetto alla definizione di dato personale?

L'**EU Data Act** (in vigore da settembre 2025) garantisce a utenti (individui e imprese) un maggiore controllo sui dati generati da dispositivi connessi (IoT) e servizi. I produttori sono obbligati a rendere questi dati accessibili agli utenti.

Aspetti chiave:

- **User Data Access & Control:** gli utenti possono accedere e condividere con terze parti i dati generati dai prodotti (smart home, auto, macchinari industriali).
- **Fairness in Data Sharing:** restringe i produttori dall'imporre termini contrattuali iniqui che blocchino gli utenti in servizi proprietari.
- **Cloud Switching:** facilita lo spostamento di dati e applicazioni tra cloud provider diversi senza costi aggiuntivi.
- **Public Sector Access:** gli enti pubblici possono richiedere dati da aziende private in situazioni eccezionali (emergenze pubbliche).

- **International Transfers:** regole per prevenire l'accesso illecito di governi di paesi terzi ai dati non personali.

Il **Digital Omnibus** (proposta del 19 novembre 2025) è un pacchetto di proposte della Commissione Europea per **semplificare il quadro normativo digitale** (GDPR, AI Act, NIS2), riducendo la burocrazia per le imprese (specialmente le PMI) mantenendo le protezioni dei cittadini.

Proposte principali: chiarimento dell'applicazione del GDPR su dati personali e interesse legittimo; semplificazione delle normative sui cookie; meccanismi “stop-the-clock” per rendere le regole sull'IA più favorevoli all'innovazione; Single-Entry Point per la segnalazione di incidenti di cybersecurity; estensione del periodo di notifica di data breach da 72 a **90 ore**.

Il punto più controverso – rilassamento della definizione di dato personale: la proposta stabilisce che, per determinare se una persona è identificabile, vanno considerati **tutti i mezzi che ragionevolmente potrebbero essere usati** per identificarla, e che l'esistenza di informazioni aggiuntive che abilitano l'identificazione **non implica automaticamente** che i dati pseudonimizzati siano dati personali per chiunque li detenga. In particolare, un dato non va considerato personale per un'entità se quell'entità non dispone dei mezzi per identificare la persona fisica. Questo è motivato anche da esigenze di IA/ML: identificare ed eliminare bias nei dataset (un interesse legittimo ex Art. 6(1)(f) GDPR) richiede spesso dati sensibili, e l'Omnibus propone eccezioni al divieto di trattamento di categorie speciali, a condizione che il controller adotti misure tecniche per rimuovere tali dati una volta identificati o protegga efficacemente i dati se la rimozione è sproporzionata.

Come lo spiegherei a voce

Il Data Act risolve un problema molto concreto: oggi compriamo dispositivi smart (auto, elettrodomestici) che generano enormi quantità di dati su come li usiamo, ma quei dati restano quasi sempre solo al produttore, che li usa per i suoi scopi (anche commerciali) senza che l'utente possa portarseli via o condividerli con un servizio concorrente. Il Data Act dà all'utente il diritto di accedere a quei dati e di spostarli, un po' come la portabilità numerica per i telefoni. Il Digital Omnibus invece va nella direzione opposta rispetto allo spirito originale del GDPR: punta a semplificare e ridurre la burocrazia, e il punto più delicato è la proposta di restringere la definizione di “dato personale” – un dato pseudonimizzato non sarebbe più automaticamente considerato personale se chi lo detiene non ha concretamente i mezzi per re-identificare la persona, anche se in teoria qualcun altro potrebbe farlo. È una scelta di compromesso tra protezione rigorosa e fattibilità pratica per le imprese, specialmente per la ricerca in IA.

22 δ -Presence e Membership Disclosure

Domanda 26: δ -Presence e Membership Disclosure

Cos'è la membership disclosure? Come la δ -presence la affronta, a differenza della k-anonymity?

Il problema: la k-anonymity protegge dall'identificazione di un individuo nel dataset rilasciato, ma **non nasconde necessariamente se un dato individuo sia presente** nel dataset stesso. Poiché generalizzare o sopprimere i quasi-identificatori non cambia la loro distribuzione nella popolazione generale, se un dataset anonimizzato contiene 10 record con un certo QI e ci sono esattamente 10 persone nella popolazione con quel QI, sapere che un individuo è nel dataset rivela già informazioni sensibili (es. che ha una certa malattia), anche senza identificarlo con precisione.

Contesti critici: database di sospetti terroristi (rivelare la presenza è dannoso); database di pazienti con un tipo specifico di cancro (rivelare la presenza svela la diagnosi).

Definizione: δ -Presence – Nergiz, Atzori, Clifton, SIGMOD 2007

Siano T una tabella pubblica esterna, PT la tabella privata (sottoinsieme di T), GT la generalizzazione di PT rilasciata pubblicamente. La δ -presence vale con $\delta = (\delta_{min}, \delta_{max})$ se:

$$\delta_{min} \leq P(t \in PT \mid GT) \leq \delta_{max} \quad \forall t \in T$$

Intuizione: la probabilità che un individuo sia nella tabella privata deve restare in un range controllato – non troppo alta (altrimenti si deduce con certezza che è presente) né troppo bassa (altrimenti si deduce che è assente). Esempio tipico: $\delta = [1/3, 2/3]$.

Monotonicità: se GT^1 è δ -present rispetto a T e PT , e GT^2 è una generalizzazione ulteriore di GT^1 , allora anche GT^2 è δ -present. Questa proprietà (analoga a quella della k-anonymity) permette di riusare gli stessi algoritmi (es. Samarati, Incognito) anche per calcolare la δ -presence.

Come si scelgono δ_{min} e δ_{max} : tipicamente bilanciando il costo di un uso improprio dei dati (es. \$10.000/anno per paziente nel caso del diabete) contro un costo atteso accettabile, partendo dalla *prior belief* (probabilità di base nella popolazione) e calcolando come questa si aggiorna in una *posterior belief* dopo aver osservato GT .

Come lo spiegherei a voce

Il modo più intuitivo di spiegare la δ -presence è far notare cosa la k-anonymity *non* copre: anche se nessuno può identificare con certezza chi sei tra k persone, sapere che sei comunque in un certo database (es. di pazienti oncologici) può già essere un'informazione sensibile, anche senza sapere quale dei k record sia il tuo. La δ -presence mette un vincolo sulla *probabilità di appartenenza* al dataset privato, non sull'identificazione precisa: questa probabilità deve restare in un intervallo controllato, perché se fosse troppo alta saprei con certezza che sei dentro, e se fosse troppo bassa saprei con certezza che sei fuori – in entrambi i casi avrei imparato qualcosa che non dovrei sapere. La cosa elegante è che, essendo una proprietà monotona come la k-anonymity, si possono riusare gli stessi algoritmi (Samarati, Incognito) già visti per calcolarla.

23 Database Auditing

Domanda 27: Database Auditing

Cos'è l'auditing di un database? Quali modelli di auditing esistono?

L'**auditing** è il processo di esame e validazione di documenti, dati, processi, procedure e sistemi, per assicurare che il sistema funzioni e sia conforme a policy, regolamenti e leggi. Viene eseguito **dopo** che il prodotto è stato messo in produzione.

Terminologia: *audit log* (documento cronologico delle attività auditate), *auditor* (persona autorizzata a effettuare l'audit), *audit trail* (registro cronologico di modifiche/eventi), *data audit* (registro delle modifiche ai dati).

Tipi: *internal auditing* (condotto da membri dello staff dell'organizzazione) vs. *external auditing* (condotto da una terza parte indipendente).

Processo di auditing (tre fasi): Understand objectives → Review, verify and validate → Report and document.

Tre modelli di database auditing:

1. **Audit per entità e azione:** registra le entità auditate (utente, tabella, colonna) e traccia cronologicamente le attività (transazioni DML, logon/logoff) e lo stato dell'entità (active, deleted, inactive).
2. **Audit per variazione di colonna:** registra solo le modifiche ai valori di colonna, con meccanismo di purging/archiving per ridurre lo spazio; non registra il tipo di azione; ideale per auditare una o due colonne specifiche.
3. **Historical auditing model:** usato quando serve un registro dell'intera riga (tipico in applicazioni finanziarie); si crea una tabella di history con la stessa struttura della tabella originale, dove ogni modifica genera una nuova riga storica.

Relazione con GDPR e privacy: l'auditing è uno dei pilastri per rendere un sistema informativo conforme al GDPR, insieme al controllo degli accessi basato su attributi (ABAC), alla cifratura e al data masking. Permette di dimostrare l'*accountability* richiesta dal regolamento: sapere chi ha creato, modificato o cancellato informazioni, quando e per quale scopo.

Come lo spiegherei a voce

L'auditing si può spiegare come la "scatola nera" di un database: non impedisce che qualcosa vada storto, ma garantisce che si possa sempre ricostruire cosa è successo, chi l'ha fatto e quando. La distinzione tra i tre modelli si capisce bene pensando a cosa interessa davvero tracciare: se mi interessa sapere chi ha fatto cosa e quando su qualsiasi tabella, uso il modello per entità e azione; se mi interessa solo sapere come è cambiato il valore di una colonna specifica nel tempo (tipico per dati sensibili come lo stipendio), uso il modello per variazione di colonna, più leggero; se invece devo conservare ogni singola versione storica di una riga intera, come in un sistema bancario dove serve sapere esattamente come era un conto in ogni istante, uso il modello storico con una tabella parallela di history. L'auditing è importante per il GDPR perché è uno dei modi concreti con cui un'azienda *dimostra* l'*accountability*, non solo afferma di essere conforme.

24 Tipi di Privacy e Caratteristiche dei Big Data

Domanda 28: Tipi di Privacy e Caratteristiche dei Big Data

Quali tipi di privacy si distinguono? Cosa caratterizza i Big Data e qual è la "legge delle conseguenze inattese"?

Tipi di privacy: *political privacy* (protezione di opinioni e attività politiche), *consumer privacy* (tutela dei dati dei consumatori da uso commerciale), *medical privacy* (riservatezza dei dati sanitari), *private property* (protezione dei beni personali), *information/data privacy* (gestione e tutela delle informazioni personali digitali).

Definizione: Big Data

L'acquisizione e l'analisi di enormi collezioni di informazioni, talmente grandi che fino a poco tempo fa la tecnologia per analizzarle non esisteva.

Datafication: il fenomeno per cui tutto viene convertito in dati (carte di credito, registri di chiamate, dati sanitari, email, social, DNA). Crea un trade-off: più privacy $\Leftrightarrow$ meno comodità.

Caratteristiche chiave dei Big Data: grandi quantità di dati non strutturati ("messy data"); evidenziano pattern altrimenti non rilevabili; raccolta indiscriminata (senza un obiettivo preciso); conservazione indefinita per utilizzi futuri imprevedibili.

Definizione: Legge delle Conseguenze Inattese

Tecnologie create per uno scopo specifico vengono poi usate per scopi completamente diversi, con implicazioni per la privacy impreviste al momento della creazione.

Esempi: il **Social Security Number** (SSN), creato per la previdenza sociale, oggi è usato come identificatore universale; i **telefoni cellulari**, pensati per le comunicazioni vocali, sono oggi usati per pagamenti, GPS, autenticazione; i **laser**, inventati per la fisica, oggi leggono DVD e codici a barre; il **DNA**, raccolto per prova forense o diagnosi genetica, è oggi usato anche per genealogia e discriminazione assicurativa.

Perché è rilevante per la privacy: quando un dato viene raccolto, è quasi impossibile prevedere tutti gli usi futuri che ne verranno fatti – questo è uno dei motivi per cui principi come la limitazione dello scopo (purpose limitation) e la minimizzazione dei dati nel GDPR sono importanti: riducono la superficie di rischio per usi non previsti al momento della raccolta.

Come lo spiegherei a voce

La “legge delle conseguenze inattese” è probabilmente l’osservazione più semplice ed efficace da portare a voce su questo argomento: quasi ogni tecnologia, una volta creata per uno scopo specifico, finisce per essere usata per qualcosa di completamente diverso e spesso imprevisto. Il Social Security Number americano è l’esempio perfetto: nato per gestire la previdenza sociale, oggi è diventato un identificatore universale usato ovunque, dalle banche alle scuole, proprio perché era comodo riusarlo – ma questo riuso crea rischi di privacy che nessuno aveva previsto al momento della sua creazione. Questo è il motivo per cui principi come la limitazione dello scopo nel GDPR sono importanti: non possiamo prevedere tutti gli usi futuri di un dato, quindi la strategia più sicura è limitare fin dall’inizio per cosa quel dato può essere usato.

25 Classificazione e Ciclo del Machine Learning

Domanda 29: Classificazione e Ciclo del Machine Learning

Cos’è un classificatore ottimale? Come si articola il ciclo del Machine Learning e dove si introduce il bias?

Definizione: Classificazione

Processo di determinare un valore plausibile per Y (target) dato X (covariate/dati). Si apprende una funzione $f_\theta : X \rightarrow \hat{Y}$. L’accuratezza è $P(Y = \hat{Y})$.

Classificatore ottimale (Bayesiano): minimizza il valore atteso del costo $\mathbb{E}[l(Y, \hat{Y})]$. Equivalentemente: $\hat{Y} = f(X) = 1$ se $\mathbb{P}(Y = 1|X = x) > 1/2$, altrimenti 0. Se conoscessimo esattamente le probabilità reali, la scelta che minimizza in media gli errori è scommettere sulla classe più probabile. In pratica i modelli ML stimano $\mathbb{P}(Y = 1|X = x)$ dai dati, senza conoscerla esattamente: questa formula serve da limite teorico ideale con cui confrontare un classificatore reale.

Definizione: Ciclo ML

Stato del Mondo $\xrightarrow{\text{Measurement}}$ Data $\xrightarrow{\text{Learning}}$ Model $\xrightarrow{\text{Action}}$ Individuals $\xrightarrow{\text{Feedback}}$ Stato del Mondo.

Le quattro fasi:

- **Misurazione:** il processo in cui lo stato del mondo viene ridotto a tabelle di dati; alcune caratteristiche possono essere non osservabili.
- **Apprendimento:** ricerca di buoni parametri θ per f .
- **Azioni:** come le decisioni del modello vengono impiegate su input nuovi.
- **Feedback:** registrazione delle reazioni/risultati, che tornano a influenzare lo stato del mondo.

Dove si introduce il bias nel ciclo: ci sono dati sufficienti per tutti i gruppi? Le misurazioni sono di parte (alcuni gruppi misurati meno accuratamente)? L'assunzione che gli errori siano indipendenti tra i gruppi è quasi sempre falsa nella realtà. Questo crea il *feedback loop* discriminatorio: dati distorti $\rightarrow$ modello distorto $\rightarrow$ decisioni distorte $\rightarrow$ nuovi dati ancora più distorti, perpetuando o amplificando le disuguaglianze esistenti.

Come lo spiegherei a voce

Il classificatore bayesiano ottimale si spiega bene con un esempio semplice: se sapessi con certezza che una persona con un certo profilo ha il 70% di probabilità di essere a rischio, la scelta più sensata in media è prevedere "a rischio" – non perché sia sempre vero, ma perché su tante persone con quel profilo, scommettere sulla maggioranza minimizza il numero totale di errori. Il problema è che in pratica non conosciamo mai questa probabilità esatta: un modello ML cerca di stimarla dai dati, e qui entra in gioco il ciclo ML, che è utile raccontare come una catena dove ogni anello può introdurre bias – le misurazioni potrebbero non catturare bene la realtà per certi gruppi, l'apprendimento potrebbe funzionare meglio per i gruppi più rappresentati nei dati, e le azioni del modello finiscono per generare nuovi dati (feedback) che richiudono il cerchio, spesso rafforzando i bias di partenza invece di correggerli.

26 Interventi di Fairness e Soppressione

Domanda 30: Interventi di Fairness e Soppressione

Quali tipi di interventi esistono per migliorare la fairness di un modello? Cos'è la soppressione e qual è il suo limite?

Tre momenti di intervento nel ciclo ML:

- **Pre-processing:** cambiare i dati di input X o i target Y (o entrambi) *prima* del training – ad esempio rimuovendo attributi correlati a quelli sensibili, o ri-pesando il dataset.
- **In-processing:** cambiare il processo di learning f_θ stesso, aggiungendo vincoli o penalizzazioni di fairness alla funzione di costo durante il training.
- **Post-processing:** modificare le predizioni $\hat{Y}$ *dopo* che il modello è già stato addestrato, per soddisfare un criterio di fairness desiderato.

Definizione: Soppressione per Fairness

Trovare le caratteristiche in X che sono correlate con le informazioni sensibili A e rimuoverle dal dataset prima del training. È un tipo di intervento di pre-processing.

Limite principale: la soppressione, da sola, raramente funziona, perché esistono **proxy attributes** – attributi apparentemente innocui (codice postale, nome, parole chiave usate) fortemente correlati con l’attributo sensibile. Rimuovere A esplicitamente non impedisce al modello di “recuperare” implicitamente la stessa informazione tramite questi proxy. Questo è anche noto come il **paradosso dell’inconsapevolezza** (fairness through unawareness): l’inconsapevolezza pura è difficile da garantire nei dati del mondo reale.

Nozione più generale: la **mutua informazione di Shannon** tra X (o un suo sottoinsieme di feature) e A misura quanta informazione su A è recuperabile da X , anche indirettamente tramite correlazioni complesse e non lineari – non solo tramite singoli attributi proxy identificabili a mano. Un approccio di soppressione più rigoroso cerca di minimizzare questa mutua informazione residua, non solo rimuovere gli attributi più ovviamente correlati.

Come lo spiegherei a voce

Il modo più chiaro per ricordare i tre momenti di intervento è pensarli rispetto al training: prima (pre-processing, modifico i dati), durante (in-processing, modifico come il modello apprende aggiungendo vincoli alla funzione di costo), dopo (post-processing, modifico le decisioni finali del modello già addestrato). La soppressione è l’intervento di pre-processing più intuitivo – togliere l’attributo sensibile – ma è anche il più ingenuo, perché quasi sempre esistono proxy attributes che permettono al modello di “indovinare” lo stesso l’informazione che ho cercato di nascondere (il classico esempio è il codice postale, spesso fortemente correlato con la composizione etnica di un’area). Per questo la nozione di mutua informazione di Shannon è più robusta della semplice rimozione manuale di attributi: misura quanta informazione sull’attributo sensibile resti recuperabile dai dati anche indirettamente, non solo tramite correlazioni ovvie.

27 Algoritmi per Statistical Disclosure Control

Domanda 31: Algoritmi per Statistical Disclosure Control su Macrodata e Microdata

Quali algoritmi/metodi si usano per fare Statistical Disclosure Control? Distinguere non-perturbativi da perturbativi, per macrodata e microdata. Come si valutano?

Distinzione di fondo: i metodi **non-perturbativi** non modificano i valori originali (li sopprimono, li raggruppano o ne pubblicano solo un sottoinsieme); i metodi **perturbativi** modificano i valori introducendo rumore o sostituzioni controllate.

Metodi SDC per Macrodata (tabelle aggregate):

- **Non-perturbativi: Cell Suppression (CS)** – soppressione delle celle a rischio (*primaria*) e di celle aggiuntive per proteggere quelle primarie (*secondaria*).
- **Perturbativi: Random Rounding (RR)** (arrotondamento casuale per difetto/eccesso); **Controlled Rounding (CR)** (arrotondamento classico controllato); **Controlled Tabular Adjustment (CTA)** (i valori sensibili sono rimpiazzati da valori simili, le altre celle vengono corrette per mantenere i totali).

Metodi SDC per Microdata (record individuali):

- **Perturbativi: aggiunta di rumore** (preserva media e correlazioni); **microaggregazione** (si partizionano i record in gruppi simili e si pubblica solo la media di gruppo); **data swapping** (si scambiano casualmente i valori di un attributo in un range ristretto); **post-randomizzazione** (cambia attributi categorici secondo matrici di transizione).

- **Non-perturbativi: sampling** (si pubblica solo un campione); **generalizzazione** (valori numerici sostituiti da intervalli, categorie combinate in classi più ampie); **top/bottom coding** (valori sopra/sotto soglia sostituiti da un estremo); **soppressione locale** (alcune celle vengono oscurate, aumentando la dimensione dei gruppi).
- Un approccio alternativo è il **rilascio di dati sintetici** (fully o partially synthetic), che pone il problema di mantenere validità statistica evitando overfitting (che reintroduce rischio di re-identificazione).

Metodi SDC per dati interrogabili (query su Statistical Database): **query restriction** (si rifiuta di rispondere a query rischiose, richiede di tracciare le query precedenti); **data perturbation** (si crea una versione perturbata del database su cui rispondere alle query); **output perturbation** (si perturba solo il risultato della query, non i dati sottostanti).

Come si valutano – Information Loss: poiché non è sempre chiaro a priori cosa l'utente finale voglia fare con i dati, l'utilità residua si misura indirettamente tramite la perdita di informazione introdotta dal metodo SDC:

- **Macrodata:** per la cell suppression, il numero (o la magnitudine) delle soppressioni secondarie; per rounding/CTA, la somma delle distanze tra celle vere e celle perturbate.
- **Microdata:** confronto delle statistiche di base (medie, varianze, covarianze) prima e dopo l'SDC; oppure tramite **divergenze** come KL e JS, che misurano quanto la distribuzione perturbata si discosta da quella originale.

Il **ciclo SDC** è iterativo: Dati $\rightarrow$ Metodo SDC $\rightarrow$ Misura di Utilità + Misura di Rischio $\rightarrow$ si ripete finché non si trova un compromesso accettabile tra le due (zona “concessa” invece che “proibita” nel piano rischio/utilità).

Come lo spiegherei a voce

Il modo più facile per ricordare questa lista a voce, invece di elencare meccanicamente i nomi, è ragionare sulla differenza di fondo: nei metodi non-perturbativi io decido di “nascondere” qualcosa (sopprimo una cella, pubblico solo un campione, raggruppo in categorie più larghe), ma quello che resta visibile è comunque vero al 100%. Nei metodi perturbativi invece tutto quello che pubblico è visibile, ma non è più esattamente vero – ho aggiunto rumore, scambiato valori, o sostituito con una media di gruppo. La scelta tra le due famiglie è in fondo un'altra faccia del trade-off rischio/utilità: nascondere preserva la veridicità di ciò che resta ma riduce la quantità di informazione disponibile; perturbare mantiene tutta l'informazione ma la rende meno precisa. L'Information Loss è semplicemente il modo di misurare quanto di questo compromesso abbiamo pagato, confrontando le statistiche prima e dopo l'intervento.

28 Perché si chiama “Differential” Privacy?

Domanda 32: Perché si chiama “Differential” Privacy?

Perché la Differential Privacy si chiama così? Scrivere la definizione formale.

Il nome “**differential**” deriva dal fatto che la garanzia di privacy non riguarda il dataset nel suo complesso, ma la **differenza** di comportamento del meccanismo tra due dataset che variano per un solo record. In altre parole, la DP misura quanto l'output *cambia* (differisce) quando un singolo individuo viene aggiunto o rimosso dal dataset – se la differenza è trascurabile, la presenza di quell'individuo è effettivamente “nascosta” nel risultato.

Definizione formale: due dataset D, D' si dicono *adiacenti* ($D \sim D'$) se differiscono per esattamente un record. Un meccanismo randomizzato $\mathcal{M}$ preserva la ε -differential privacy se per ogni query q , ogni coppia di dataset adiacenti D, D' e ogni possibile risposta r :

$$e^{-\varepsilon} \leq \frac{\mathbb{P}(\mathcal{M}(q, D) = r)}{\mathbb{P}(\mathcal{M}(q, D') = r)} \leq e^{\varepsilon}$$

Punto importante da sottolineare: questa definizione è estremamente **generale** – vale per *qualsiasi* query q e per *qualsiasi* coppia di dataset adiacenti D, D' , non per un caso specifico. È questa universalità (la garanzia regge indipendentemente da cosa stia chiedendo l'analista e da quale sia il dataset reale) che rende la DP una garanzia matematicamente dimostrabile e robusta contro qualsiasi conoscenza pregressa dell'avversario, a differenza di k-anonymity o l-diversity che proteggono solo da specifici tipi di attacco.

Come lo spiegherei a voce

Se dovessi dirlo a voce in due frasi: il nome viene dal fatto che si guarda la “differenza” tra due mondi quasi identici (con o senza una persona), e si richiede che quella differenza nell'output sia impercettibile. Il dettaglio da non perdere è che questa proprietà deve valere per *ogni* query possibile e *ogni* dataset possibile – non è una garanzia “su misura” per un caso specifico, è una proprietà universale del meccanismo, e questo è esattamente ciò che la rende così più forte di k-anonymity o l-diversity.

29 Domande di Ragionamento Aperto

Domanda 33: Domande di Ragionamento Aperto

Alcune domande d'esame non hanno una risposta univoca dalle slide, ma richiedono di ragionare collegando concetti del corso. Le riporto con una possibile linea di ragionamento.

“Se tu dovessi calcolare l'utilità, come faresti?” Una possibile risposta è trattare l'utilità come una funzione della **quantità di informazione** residua nei dati, misurabile in bit (collegandosi a entropia, KL/JS divergence, information loss). Questo inquadramento spiega naturalmente il trade-off privacy-utilità: più rumore o generalizzazione si aggiunge, più bit di informazione si perdono, meno utili diventano i dati.

“L'Access Control (RBAC/ABAC) ha a che fare con l'utilità?” Sì, indirettamente: una policy di accesso più permissiva aumenta l'utilità percepita dai destinatari autorizzati (più dati visibili a chi ne ha diritto) ma non riduce il rischio di disclosure per chi non è autorizzato – il controllo degli accessi sposta il punto di compromesso rischio/utilità a seconda di *chi* sta guardando il dato, invece di applicare la stessa protezione a tutti indiscriminatamente (come fanno invece k-anonymity o DP).

“L'utilità del dato dipende dal singolo individuo?” Esempio discusso: un politico può voler rendere pubblico il proprio stato di salute (alta utilità per lui nel comunicarlo), mentre un cittadino comune preferisce la massima riservatezza sullo stesso tipo di dato. Questo mostra che l'utilità (e il livello di protezione desiderato) non è una proprietà solo del dato in sé, ma anche delle preferenze del soggetto a cui il dato si riferisce – un'osservazione che motiva approcci come l'ABAC, dove le policy possono essere personalizzate per singolo soggetto/risorsa, a differenza di un approccio SDC uniforme su tutto il dataset.

“Perché nel corso associamo l'etica alla privacy?” Domanda aperta a cui si può rispondere richiamando i temi discussi nella prima parte del corso: la privacy non è solo un problema tecnico di protezione dei dati, ma tocca la **dignità umana** (Rodotà), la **libertà civile** (Snowden, Greenwald – la sorveglianza di massa altera il comportamento anche di chi “non ha

nulla da nascondere”), e le conseguenze sociali della discriminazione algoritmica (fairness). La componente tecnica (k-anonymity, DP, SMC) fornisce gli **strumenti**, ma le domande su quando e perché usarli sono intrinsecamente etiche.